

ISLAMIC UNIVERSITY OF TECHNOLOGY (IUT)
ORGANISATION OF ISLAMIC COOPERATION (OIC)
Department of Computer Science and Engineering (CSE)

SEMESTER FINAL EXAMINATION
DURATION: 3 HOURS

WINTER SEMESTER, 2024-2025
FULL MARKS: 150

CSE 4531: E-Commerce and Web Security

Programmable calculators are not allowed. Do not write anything on the question paper.

Answer all 6 (six) questions. Figures in the right margin indicate full marks of questions with corresponding COs and POs in parentheses.

1. a) A university operates an internal web portal called `campushub.edu`, where students can update their profile information, register for courses, and manage various campus services.

 A student named Rahim logs into the portal and leaves the browser tab open. While browsing other websites, he visits an external blog that offers free programming tutorials. Without Rahim's knowledge, the blog page contains a hidden form that automatically submits a request to `campushub.edu`. This request instructs the university server to update the email address associated with Rahim's account to an address controlled by the attacker. The university server processes the request and updates the email address without requiring additional confirmation from Rahim.
 Based on the scenario described above, answer the following questions.
 - i. Name the security attack illustrated in this incident. 1
 - ii. Explain why the server processes the request as legitimate. 3
(CO2)
(PO2)
 - iii. Discuss two security mechanisms that can be implemented to prevent this type of attack. 7
(CO2)
(PO2)
 - b) In a separate incident on the portal described in Question 1.a, students are allowed to post comments in the course discussion forum. A malicious student posts a comment containing embedded JavaScript code. When other students open the discussion page, the script executes in their browsers and silently sends their session information to the attacker's server.
 Based on the scenario described above, answer the following questions.
 - i. Name the security attack illustrated in this incident. 1
 - ii. Based on the two incidents described in Question 1.a and Question 1.b, explain the key conceptual differences between the two attacks in terms of their attack mechanism, target, and protection mechanisms. 6
(CO2)
(PO2)
 - c) What security risks arise from weak session management and weak credential management in web applications? Provide two example attacks associated with each. 7
(CO2)
(PO2)
2. a) How does the *PageRank* algorithm work, and how does it influence search engine ranking? 6
(CO1)
(PO1)
 - b) Define *A/B testing* and illustrate its application with an industry case study demonstrating how it improved website performance and user experience. 7
(CO1)
(PO1)
 - c) Explain how digital analytics works in the context of an e-commerce platform. Discuss how digital analytics insights can be used to optimize marketing strategies and enhance user experience. 7
(CO3)
(PO6)
 - d) What key demand-side factors should be considered when estimating the hardware capacity required for the optimal operation of an e-commerce platform? 5
(CO1)
(PO1)

3. a) What is the 'Right to Be Forgotten'? Discuss its importance in protecting user privacy on digital platforms with an appropriate example. 5
(CO4)
(PO3)
- b) Consider a large e-commerce marketplace where multiple independent sellers list products, upload images, and sell goods to customers. The platform faces several *Intellectual Property Rights (IPR)* issues. The following situations illustrate these issues:
- One seller copies product descriptions and images from another seller's product page.
 - Another company attempts to use a brand name and logo that closely resemble those of an existing brand, potentially causing customer confusion.
 - Meanwhile, a startup claims to have developed a new AI-based recommendation system for online shopping and seeks legal protection for its innovation.
- i. For each of the situations described above, identify the appropriate form of intellectual property protection. 3
(CO4)
(PO8)
- ii. For each identified form of protection, explain the rights granted to the owner and the limitations applicable to normal users (non-owners) when using such protected material. 6
(CO4)
(PO8)
- c) Identify the key areas that are typically examined during a *web application vulnerability assessment* for an e-commerce platform. 6
(CO2)
(PO2)
- d) Briefly describe the key activities involved in the *Secure Software Development Lifecycle (Secure SDLC)* when developing web applications for an e-commerce platform. 6
(CO2)
(PO2)
4. a) An e-commerce system requires multiple security technologies and protection mechanisms to safeguard its infrastructure, applications, and customer data. Based on these security requirements:
- i. List three security technologies or mechanisms used to secure network infrastructure and communication channels. 3
(CO2)
(PO2)
- ii. Describe three security measures that help protect application software and servers from potential security threats. 3
(CO2)
(PO2)
- iii. State three methods used to protect sensitive customer data during storage or transmission. 3
(CO2)
(PO2)
- b) A digital content distribution platform provides software applications and updates to remote client systems over the Internet. During data transmission, the platform must ensure that:
- the transmitted data remains confidential and unreadable to unauthorized parties,
 - the client can detect any modification or tampering of the transmitted data, and
 - the client can verify the authenticity of the message source.
- Describe and justify the security mechanisms that should be implemented to achieve these objectives during data transmission. 9
(CO2)
(PO2)
- c) In an e-commerce system, multiple layers of security mechanisms are often deployed at the network, communication, and infrastructure levels to protect the platform and its transactions. 7
(CO2)
(PO2)
- In such an environment, is *secure coding* still necessary? Justify your answer with an appropriate example.

5. a) An e-commerce website allows customers to log in to manage their accounts, place orders, and view purchase history. During registration, the system requires users to create a password containing at least five characters. The system stores user passwords by encrypting them using a private key maintained by the server.

The login page uses *HTTPS* to protect communication between the client and the server. When users log in successfully, the system creates a session with a randomly generated session identifier that allows access to account information, order history, and saved payment details. The platform records failed login attempts in its logs and does not enforce any delay or restriction on repeated login attempts from the same account.

To improve user convenience, if the browser is reopened shortly after logout, the user can access their account without being required to authenticate again. To streamline account management and checkout processes, once a user is authenticated, the system allows the user to modify their account details or view saved payment information without requiring them to re-enter their password. Furthermore, whenever account credentials are changed, the system sends a notification email to the user's registered email address.

- i. Based on the scenario described above, identify and explain the weaknesses in the authentication process that could lead to *broken authentication* vulnerabilities. 8
(CO2)
(PO2)
 - b) Explain the difference between a traditional *Network-based Firewall* and a *Web Application Firewall (WAF)*. 5
(CO2)
(PO2)
 - c) Describe the core principles of the *Zero Trust* security model. How does this model differ from traditional perimeter-based security approaches? 5
(CO2)
(PO2)
 - d) What is the *Cyber Kill Chain* and why is it useful for security professionals? 5
(CO2)
(PO2)
6. a) List any five important factors that contribute to the successful design of an e-commerce website. 5
(CO1)
(PO1)
- b) Define accessibility rules in the context of e-commerce websites and briefly discuss their importance. 4
(CO1)
(PO1)
- c) For each of the following *Search Engine Optimization (SEO)* components, explain how it improves search engine rankings and list the key activities involved. 8
(CO1)
(PO1)
- i. On-Page SEO
 - ii. Off-Page SEO
 - iii. Technical SEO
 - iv. Local SEO
- d) Compare the impact of *Search Engine Optimization (SEO)* and *Search Engine Marketing (SEM)* on website visibility and online traffic generation. 3
(CO3)
(PO6)
- e) Discuss the concept of *viral campaigns* in *Social Media Marketing (SMM)*. Describe how *Content Marketing* strategies contribute to the success of such campaigns. 6
(CO3)
(PO6)